

SAMPLE INCIDENT REPORT

Multi-Stage Intrusion at Meridian Grove Logistics

From Vendor-Themed Phishing to Domain-Wide Ransomware

Case Reference: SAMPLE-2026-0417 | Prepared: July 15, 2026

Prepared for internal tooling test purposes

This is a synthetic sample created to test and calibrate security-technique mapping and detection tooling. Meridian Grove Logistics is a fictional organization. All individuals, systems, IP addresses, domains, and events described in this document are invented for illustrative purposes and do not describe any real incident, company, or person.

Executive Summary

This report documents a simulated intrusion against Meridian Grove Logistics (“MGL”), a fictional mid-sized freight and warehousing company, developed to exercise attack-mapping and detection tooling against a realistic, technique-diverse narrative. The scenario traces an intrusion that began with a reconnaissance email against the IT helpdesk, escalated into a spearphishing compromise of a build engineer's workstation, pivoted through a poisoned internal software package into MGL's containerized build pipeline, broke out of a container to seize control of the underlying Linux host, harvested and cracked local credentials, moved laterally into the Windows Active Directory domain, escalated to Domain Admin through ticket forgery and an access-control list change, and culminated in surveillance of executive workstations, theft of sensitive data, domain-wide file encryption, and a ransom demand.

The purpose of this document is to provide a coherent, end-to-end fictional incident narrative — covering reconnaissance, initial access, execution, persistence, privilege escalation, defense evasion, credential access, lateral movement, collection, exfiltration, and impact — without referencing any specific classification framework, technique catalog, or identifier. Section 11 offers remediation recommendations organized by the stage of the intrusion they address.

Incident Timeline

Date / Time	Activity
Day 1, 09:14	Reconnaissance email sent to IT helpdesk posing as a vendor-onboarding contact; helpdesk discloses DevOps staff names and emails.
Day 4, 14:02	Spearphishing email with a macro-enabled “invoice” sent to Senior DevOps Engineer R. Alvarez.
Day 4, 14:07	Macro executed; loader downloaded and initial foothold established on Alvarez’s workstation.
Day 6	Trojanized internal package (swift-metrics-shim) published and pulled by the CI pipeline; injected code executes inside the build process.
Day 7	Cron entry and a new local account (svc-metrics) created on the CI host for persistence.
Day 8	Container escape from the CI build container to the underlying Linux host; sudoers misconfiguration abused to obtain root.
Day 9	Artifacts hidden via timestomping and disguised paths; a locally built container image used to stage tools without registry pulls; kernel-module rootkit installed.
Day 10	/etc/shadow copied off host and cracked offline; SSH key persistence added to a build-automation account.
Day 12	Lateral movement into the Windows domain via a reused service-account password, alternating between SSH, RDP, and WinRM.
Day 13	Kerberos service tickets requested and cracked offline (Kerberoasting) against weakly configured service accounts.
Day 15	krbtgt hash recovered from an improperly decommissioned domain controller image; golden ticket forged.

Date / Time	Activity
Day 15	Access-control list on a finance/executive OU modified to grant replication rights to an actor-controlled account.
Day 16	Actor-controlled account added to Domain Admins.
Day 18	Screen and webcam capture deployed against CFO and COO workstations.
Day 19	~40 GB of finance, HR, and contract data staged and exfiltrated over a disguised command-and-control channel.
Day 20	Domain-wide ransomware deployment; file shares and reachable backup catalogs encrypted; ransom note dropped, signed "CINDER WOLF."

Table 1. Reconstructed timeline of actor activity across the intrusion lifecycle. All dates are relative to Day 1 of the simulated scenario.

1. Initial Access and Reconnaissance

On the morning of Day 1, MGL's IT helpdesk received an email purporting to be from a new logistics-software vendor undergoing an “onboarding security review.” The message asked helpdesk analyst Tomás Reyes to confirm the names and email addresses of engineers responsible for deployment pipelines and cloud infrastructure, framing the request as a routine step in vendor due diligence. Reyes, unaware that the sender's domain had been registered only nine days earlier and closely mimicked a real partner's domain, replied with the requested organizational details — handing the actor a curated target list of MGL's DevOps staff.

Three days later, the actor used that list to send a second, more targeted email to Senior DevOps Engineer Rosa Alvarez. The message impersonated a logistics-hardware vendor and included an attached “overdue invoice” formatted as a macro-enabled spreadsheet. Alvarez opened the attachment at her workstation; the embedded macro silently downloaded and executed a small loader that established outbound contact with actor-controlled infrastructure, giving the intrusion its initial foothold.

2. Foothold, Supply Chain Compromise, and Execution

From Alvarez's workstation, the actor harvested cached credentials for MGL's internal package registry and used them to publish a trojanized version of an internal helper library, swift-metrics-shim, that MGL's build pipeline (“Forgeline CI”) pulled automatically during nightly builds. The tampered package was functionally identical to the legitimate one but contained an additional routine that reached out to actor infrastructure and injected a small payload into the running build process.

When the poisoned dependency was pulled into the CI container on build-ci-03.mgl.internal, the injected code executed inside the legitimate build process, giving the actor code execution without needing to compromise the container image directly. From there, they invoked the container's shell interpreter to run reconnaissance commands, enumerate mounted volumes, and identify credentials and configuration files reachable from the pipeline.

3. Establishing a Foothold on the Linux Build Environment

To survive container restarts and pipeline redeployments, the actor added a cron entry on the CI host that relaunched their loader every thirty minutes. In parallel, they created a new low-privilege local account, svc-metrics, styled to resemble a legitimate monitoring service account and given just enough access to blend into routine automation traffic.

The actor also planted an SSH key pair, appending their public key to the authorized_keys file of an existing build-automation account. This gave them a durable, credential-free channel back into the host that did not depend on the cron job or loader remaining undetected — and it later proved to be the actor's most resilient point of re-entry during the incident response team's initial containment attempts.

4. Privilege Escalation and Defense Evasion

The CI container was intentionally scoped with limited privileges, but a misconfigured volume mount and an outdated container runtime allowed the actor to break out of the container and obtain a shell on the underlying host itself, exposing the full Linux build server to further compromise.

Once on the host, the actor found a sudoers entry permitting the build-automation account to run a maintenance script as root without a password. The script's behavior could be influenced through an environment variable the actor controlled, and invoking it handed them a root shell.

With root secured, the actor worked to reduce the odds of discovery. They relocated their tooling into directories disguised as routine log-rotation paths, altered file modification timestamps to blend in with legitimate build artifacts, and cleared shell history tied to their sessions. To further mask activity, they built and locally tagged a new container image directly on the host — rather than pulling one from an external registry, which would have generated an outbound request an EDR tool might flag — and used that self-built image to stage additional tools without triggering registry-pull alerts.

Finally, the actor installed a kernel-level rootkit on the host designed to hide specific processes, files, and network connections from standard administrative tools, giving them a long-term, low-visibility presence that persisted across the reboots that followed MGL's routine patch cycle.

5. Credential Harvesting

With root access in hand, the actor copied the host's shadow password file off the server and cracked it offline using a combination of dictionary and rule-based attacks. Weak, reused passwords on two service accounts, and a stale root password that had not been rotated since the server's initial provisioning, fell within hours — giving the actor a set of working credentials that extended beyond the build environment itself.

6. Lateral Movement and Domain Compromise

One of the cracked service-account passwords was also valid on MGL's corporate Windows domain, meridiangrove.local — a legacy artifact of a shared-credential policy the IT team had meant to retire. The actor used it to authenticate to file server FS-DEN-02, moving from the Linux build environment into the Windows estate by alternating between SSH, RDP, and WinRM sessions depending on which protocol looked least anomalous against each destination host's normal traffic pattern.

From FS-DEN-02, the actor targeted service accounts configured with weak or outdated Kerberos encryption settings, requesting service tickets for those accounts and extracting them for offline cracking — recovering two more sets of usable domain credentials within a day.

The actor then located a decommissioned domain controller image, DC-DEN-00-legacy, that had never been securely wiped after being replaced. The image still contained the domain's krbtgt account hash, which the actor extracted and used to forge a fully privileged authentication ticket, allowing them to impersonate any account in the domain — including disabled or nonexistent ones — without further password guessing.

To cement their position, the actor modified the access-control list on an organizational unit containing MGL's finance and executive accounts, granting a low-profile service account replication-related rights normally reserved

for domain controllers. That single ACL change let them pull password data for any domain user on demand and, shortly after, add their controlled account into the Domain Admins group — giving them unrestricted control over the Windows environment.

7. Collection and Surveillance

With domain-wide access, the actor deployed a lightweight monitoring utility to the workstations of MGL's CFO and COO, quietly capturing periodic screenshots and short webcam video clips from each machine over the course of several days. The material was used to understand executive travel schedules and ongoing contract negotiations and — as later became apparent from the ransom note — to add pressure during the extortion phase of the intrusion.

8. Exfiltration

Over roughly thirty-six hours, the actor identified and staged sensitive files from finance, HR, and customer-contract shares, compressing and encrypting them locally before transmitting the archive out of the network through a command-and-control channel disguised as routine analytics traffic to a domain resembling a legitimate content-delivery service. An estimated 40 gigabytes of data left the environment before defenders identified and blocked the outbound channel.

9. Impact: Extortion and Ransomware

On Day 20, the actor triggered domain-wide ransomware deployment using their Domain Admin access, pushing an encryptor to servers and workstations across MGL's Denver headquarters and two regional distribution hubs. File shares, backup catalogs reachable from the domain, and several line-of-business databases were encrypted within roughly ninety minutes.

A ransom note, dropped on affected systems and signed by the actor's self-styled name, CINDER WOLF, demanded payment in cryptocurrency in exchange for a decryption key and threatened to publish the exfiltrated finance and HR data — along with the captured executive screen and webcam recordings — if MGL did not pay within a stated deadline.

10. Detection, Response, and Remediation

The intrusion was ultimately identified when an endpoint detection tool flagged anomalous kernel-module activity on build-ci-03 consistent with rootkit behavior, triggering an escalation to MGL's incident response retainer partner. Forensic review subsequently traced the activity backward through the cracked credentials, forged ticket, and container escape to the original phishing emails.

Response actions included isolating affected hosts, expiring the krbtgt account twice (per standard practice, to invalidate any forged tickets), disabling accounts created or modified by the actor, rotating every credential that had touched the build or domain environment, and rebuilding CI infrastructure from known-clean images. MGL restored encrypted systems from offline backups that were not reachable from the domain, avoiding payment of

the ransom — though recovery of the two regional hub systems took an additional nine days due to backup verification issues discovered during restoration.

11. Lessons Learned and Recommendations

The following recommendations are organized roughly in the order of the intrusion stages they address, from initial access through impact:

- Require out-of-band verification for any request involving staff directories or organizational structure, even when the request appears to come from a known vendor relationship.
- Extend phishing-simulation and reporting training to cover invoice- and vendor-themed lures specifically, since these were the most effective pretexts observed in this scenario.
- Enforce code-signing and provenance verification for internal and third-party packages pulled into CI/CD pipelines, and alert on any package-publish event from an unexpected source.
- Harden container runtimes and audit host mounts and capabilities granted to build containers; treat any container-escape path as a critical finding regardless of the container's intended privilege level.
- Remove standing sudo rules that allow password-less execution of scripts whose behavior can be influenced by caller-controlled input or environment variables.
- Deploy file-integrity and kernel-module monitoring on Linux build and production hosts to catch rootkit installation and artifact-hiding activity earlier in the chain.
- Decommission legacy systems, including domain controller images, through a verified secure-wipe process, and treat any surviving copy of the krbtgt hash as a domain-wide compromise.
- Regularly audit Active Directory access-control lists for unexpected replication or delegation rights, particularly on organizational units containing executive and finance accounts.
- Eliminate shared or reused credentials across Linux and Windows environments, and adopt just-in-time or vaulted credentials for cross-platform service accounts.
- Monitor for unauthorized screen-capture and webcam-access utilities on executive workstations, and apply enhanced logging and network segmentation to those endpoints.
- Maintain offline, domain-independent backups and periodically test restoration procedures under simulated ransomware conditions.
- Baseline and alert on outbound traffic to newly registered or reputationally unproven domains, particularly from build and CI infrastructure that should have predictable, limited egress patterns.

Appendix: Illustrative Indicators (Fictional)

The indicators below are entirely fictional and use IP ranges reserved for documentation purposes. They are included to give the scenario a complete, testable shape and should not be used operationally.

Type	Value	Notes
Domain	cdn-edge-metrics.example	Command-and-control / exfiltration channel (fictional)
IP address	203.0.113.44	Actor infrastructure (documentation range)

Type	Value	Notes
IP address	198.51.100.212	Secondary relay (documentation range)
Host	build-ci-03.mgl.internal	Initial Linux foothold; container escape point
Host	FS-DEN-02	First Windows lateral-movement target
Host	DC-DEN-00-legacy	Source of exposed krbtgt hash
Account	svc-metrics	Actor-created local persistence account
File	README_RECOVER_FILES.txt	Ransom note dropped domain-wide
Actor alias	CINDER WOLF	Self-identified name used in the ransom note